

Security Incident Report

Report ID	CLD-IR-0002
Related ticket	CLD-0002 – Reported phishing email impersonating Cloudora HR (payroll theme)
Report title	Payroll-themed credential phishing campaign with two compromised accounts
Analyst	Ahmad Obeid – SOC Analyst, simulated Cloudora engagement
Date of report (UTC)	2026-08-25
Incident severity	P1
Status	Investigation complete – simulated containment actions documented
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

On 25 August 2026, Cloudora was targeted by a payroll-themed phishing campaign that impersonated the company's Human Resources function and directed employees to a fraudulent payroll portal. Forty employees were targeted, six clicked the phishing links, and two—Freya Lynn and Ryan Boyd—submitted their passwords and were subsequently accessed by an external attacker. The attacker used the compromised accounts to access Outlook Web and, in Freya's case, SharePoint Online, creating a risk of email misuse and exposure of company information. The investigation identified the affected users, malicious infrastructure and remaining at-risk recipients, and documented the required containment actions, including session revocation, password resets, multi-factor authentication, infrastructure blocking and removal of the phishing messages. No confirmed data theft or fraudulent payment was identified in the available logs, but the incident remains P1 because two employee accounts were successfully compromised and actively used by the attacker.

2. Incident timeline

Time (UTC)	Source	Event	Evidence / notes
25 Aug, 06:58	Reported .eml	Legitimate Cloudora newsletter delivered	Mailchimp newsletter passed SPF, DKIM and DMARC for the genuine <code>cloudora.io</code> domain. Later investigated and cleared as a false positive.
25 Aug, 08:04–08:20	CloudoraMsgTrace_CL	Phishing variant A, first wave, delivered to Cloudora staff	Sent from <code>198.18.44.10</code> while spoofing <code>payroll@cloudora.io</code> . SPF, DKIM and DMARC failed. Some messages were quarantined by Exchange Online Protection, while others reached user inboxes.
25 Aug, 08:35–08:50	CloudoraMsgTrace_CL	Second phishing wave and variant B delivered	Variant A wave two used <code>198.18.44.23</code> . Variant B was sent from <code>198.18.51.7</code> using the lookalike domain <code>cloudora-hr-portal.example</code> . Variant B passed authentication, but only for the attacker-controlled lookalike domain.
25 Aug, 08:39:03	CloudoraMsgTrace_CL	Seth Lane clicked the variant A phishing link	Link opened from Seth's normal IP. <code>CredentialsSubmitted = No</code> ; elevated risk but no confirmed credential compromise.

25 Aug, 08:47:12	CloudoraMsgTrace_CL	Freya Lynn clicked variant A and submitted credentials	Freya visited <code>cloudora-hr-portal.example/payroll/login</code> . <code>CredentialsSubmitted = Yes</code> ; her password was treated as compromised.
25 Aug, 09:05:44	CloudoraMsgTrace_CL	Ryan Boyd clicked variant B and submitted credentials	Ryan visited <code>login.cloudora-hr-portal.example/verify</code> . <code>CredentialsSubmitted = Yes</code> ; his password was treated as compromised.
25 Aug, 09:11	reported .eml / Ticket CLD-0002	James Holt reported the suspicious payroll email to the SOC	James forwarded the message after noticing the salary-related pressure and unfamiliar HR portal. Ticket CLD-0002 was raised and the investigation began.
25 Aug, 09:58:50	CloudoraMsgTrace_CL	Hugo Marsh clicked the phishing link	<code>CredentialsSubmitted = No</code> ; no anomalous attacker sign-in was identified.
25 Aug, 10:12:37	CloudoraMsgTrace_CL	Chloe Price clicked the phishing link	<code>CredentialsSubmitted = No</code> ; no anomalous attacker sign-in was identified.
25 Aug, 10:34:20	CloudoraSignIn_CL	Attacker successfully signed in to Freya Lynn's account	Successful Microsoft 365 authentication from 198.18.7.200, Amsterdam, Netherlands, using Windows 11 and Chrome. Device and location were inconsistent with Freya's normal Manchester activity. Harvested valid credentials were used.
25 Aug, 10:36:05	CloudoraSignIn_CL	Attacker accessed Freya Lynn's mailbox	Successful Outlook Web session from 198.18.7.200, using the same Windows 11 and Chrome attacker fingerprint.
25 Aug, 10:41:48	CloudoraSignIn_CL	Attacker accessed SharePoint through Freya Lynn's account	Successful SharePoint Online session from the attacker IP. The available logs show access but do not establish whether files were downloaded or altered.
25 Aug, 11:47:19	CloudoraMsgTrace_CL	Dina Said clicked the phishing link	<code>CredentialsSubmitted = No</code> ; no anomalous attacker sign-in was identified.
25 Aug, 13:22:05	CloudoraSignIn_CL	Attacker successfully signed in to Ryan Boyd's account	Successful Microsoft 365 authentication from 198.18.7.200, Amsterdam, using Windows 11 and Chrome. Ryan normally used an iOS device from London, supporting the account-compromise verdict.
25 Aug, 13:25:33	CloudoraSignIn_CL	Attacker accessed Ryan Boyd's mailbox	Successful Outlook Web session from the same attacker IP and device fingerprint.

3. Findings.

Finding 1 – A payroll-themed phishing campaign targeted cloudora employees

On 25 August 2026, the attacker sent phishing emails to 40 Cloudora employees using two payroll-related subject lines: **“Payroll update: action required before 5pm”** and **“Action required: confirm your August payroll details.”** Both messages impersonated Cloudora's HR or payroll function and directed recipients to the lookalike domain `cloudora-hr-portal.example`.

The message-trace data showed that 36 employees received at least one phishing message in their inbox, while four employees had every copy quarantined by Exchange Online Protection. The campaign used urgency and the threat of delayed salary payments to pressure recipients into visiting a credential-harvesting website.

This matters because the activity was not an isolated malicious email; it was a coordinated campaign affecting a significant portion of the organisation.

Finding 2 – The campaign used both domain spoofing and an authenticated lookalike domain

Phishing variant A forged the genuine address payroll@cloudora.io and was sent from 198.18.44.10 and 198.18.44.23. Its SPF, DKIM and DMARC checks all failed, and the Reply-To address pointed to the unrelated domain cloudora-hr-portal.example.

Phishing variant B was sent from 198.18.51.7 using the address payroll@cloudora-hr-portal.example. SPF, DKIM and DMARC passed, but they passed only for the attacker-controlled lookalike domain, not for Cloudora's genuine cloudora.io domain.

This demonstrates that a successful authentication result does not prove an email is legitimate. It only proves that the sender was authorised to send for the domain shown in the message, which may itself be malicious.

Finding 3 – Freya Lynn and Ryan Boyd submitted credentials and were subsequently compromised

freya.lynn@cloudora.io clicked phishing variant A at 08:47:12 UTC and the message-trace record showed CredentialsSubmitted = Yes. At 10:34:20 UTC, the attacker successfully signed in to her account from 198.18.7.200 in Amsterdam using Windows 11 and Chrome. The attacker then accessed Outlook Web at 10:36:05 UTC and SharePoint Online at 10:41:48 UTC.

ryan.boyd@cloudora.io clicked phishing variant B at 09:05:44 UTC and also submitted credentials. At 13:22:05 UTC, the attacker signed in to Ryan's account from the same Amsterdam IP and device fingerprint, followed by Outlook Web access at 13:25:33 UTC.

Both users normally authenticated from the United Kingdom using different devices. The foreign sign-ins occurred after the credential submissions and used an unfamiliar Windows 11 and Chrome fingerprint, confirming that the harvested passwords were used by the attacker.

Finding 4 – Four additional employees clicked the phishing link but were not confirmed compromised

The message-trace records showed that the following employees clicked a phishing link but had CredentialsSubmitted = No:

seth.lane@cloudora.io
chloe.price@cloudora.io
hugo.marsh@cloudora.io
dina.said@cloudora.io

No successful sign-ins from the attacker IP 198.18.7.200 were identified for these users in the available sign-in logs.

They are therefore not confirmed compromised, but they remain higher risk than users who did not click because they reached the credential-harvesting page. Precautionary password resets and direct confirmation with each user are appropriate.

Finding 5 – Thirty employees received the phishing email but did not click, while four were fully protected by quarantine

The campaign-scoping query identified 30 employees who received at least one delivered phishing message but did not generate a click event. These users require awareness communications but do not require the same response as confirmed credential submitters or users who reached the phishing site.

Four additional employees—emma.hayes@cloudora.io, maya.chen@cloudora.io, nina.cole@cloudora.io and ruth.dean@cloudora.io—were targeted, but every phishing copy sent to them was quarantined by Exchange Online Protection. They did not receive the message in their inboxes.

Separating users into compromised, clicked, delivered-but-not-clicked and fully quarantined groups allows the response to remain proportionate to the evidence.

Finding 6 – The reported Mailchimp newsletter was legitimate and unrelated to the attack

The “Cloudora Monthly” newsletter reported by adam.clark@cloudora.io was sent through Mailchimp on Cloudora’s behalf. It passed SPF, DKIM and DMARC, with DKIM aligned to the genuine cloudora.io domain. The message also contained a valid one-click unsubscribe mechanism and linked to Cloudora’s authorised Mailchimp list-management domain.

Unlike phishing variant B, the newsletter’s successful authentication aligned with Cloudora’s real domain rather than a lookalike domain. It was therefore classified as legitimate marketing email and cleared as a false positive.

This prevents unnecessary blocking and ensures the same benign email is not repeatedly investigated.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
Domain	Cloudora-hr-portal.example	25 Aug 2026, approximately 08:04	Lookalike of the legitimate cloudora.io domain. Used for phishing delivery, credential-harvesting links, Reply-To addresses and campaign infrastructure. Block the domain and all subdomains.
URL	hxtps://cloudora-hr-portal[.example]/payroll/login	25 Aug 2026, 08:04	Credential-harvesting link used by phishing variant A. The URL is defanged for safe reporting.
URL	hxtps://login.cloudora-hr-portal[.example]/verify	25 Aug 2026, 08:36	Credential-harvesting link used by phishing variant B. Ryan Boyd submitted credentials through this variant.
IPv4 address	198.18.44.10	25 Aug 2026, 08:04	Variant A first-wave sending relay and phishing infrastructure. Sent messages spoofing payroll@cloudora.io; SPF, DKIM and DMARC failed.
IPv4 address	198.18.44.23	25 Aug 2026, 08:39	Variant A second-wave sending relay in the same /24 range as 198.18.44.10. Used to send the phishing email reported by James Holt.
IPv4 address	198.18.51.7	25 Aug 2026, 08:36	Variant B sending relay. Authentication passed for the attacker-controlled lookalike domain, not for the genuine Cloudora domain.
IPv4 address	198.18.7.200	25 Aug 2026, 10:34:20	Attacker sign-in IP located in Amsterdam in the training data. Used to access Freya Lynn’s and Ryan Boyd’s accounts with harvested credentials.
Sender address	payroll@cloudora.io — spoofed	25 Aug 2026, 08:04	Forged sender used by variant A. The message claimed to originate from Cloudora, but authentication failed and the actual sending infrastructure was external.
Reply-To address	hr-support@cloudora-hr-portal.example	25 Aug 2026, 08:04	External attacker-controlled Reply-To used by variant A. Replies would leave Cloudora and be delivered to the lookalike domain.

Sender address	payroll@cloudora-hr-portal.example	25 Aug 2026, 08:36	Variant B sender address using the lookalike domain. SPF, DKIM and DMARC passed only for this fake domain.
Device fingerprint	Windows 11 / Chrome	25 Aug 2026, 10:34:20	Device and browser combination associated with attacker sign-ins from 198.18.7.200. It was inconsistent with the victims' normal devices.
Subject line	Payroll update: action required before 5pm	25 Aug 2026, 08:04	Subject used by phishing variant A. Included urgency and a threat that salary payment could be delayed.
Subject line	Action required: confirm your August payroll details	25 Aug 2026, 08:36	Subject used by phishing variant B. Directed recipients to the lookalike credential-harvesting portal.

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
Initial Access	T1566.002	Phishing: Spearphishing Link	Findings 1 and 2 — both payroll-themed phishing variants contained links directing users to the lookalike credential-harvesting domain.
Credential Access	T1598.003	Phishing for Information: Spearphishing Link	Finding 3 — Freya Lynn and Ryan Boyd followed the phishing links and submitted credentials to the fake payroll portal.
Initial Access	T1078.004	Valid Accounts: Cloud Accounts	Finding 3 — the attacker used the harvested credentials to sign in successfully to Freya's and Ryan's Microsoft 365 accounts from 198.18.7.200.

The investigation directly observed spearphishing links, credential harvesting and the subsequent use of valid cloud-account credentials. The lookalike domain is mapped as contextual attacker infrastructure because its use is evidenced, but its acquisition process is not present in the available logs.

6.Scope

Accounts confirmed compromised

Two Cloudora accounts were confirmed compromised after their users submitted credentials to the phishing site and the attacker subsequently authenticated from 198.18.7.200 in Amsterdam:

freya.lynn@cloudora.io — submitted credentials at 08:47:12 UTC. The attacker successfully signed in at 10:34:20 UTC, accessed Outlook Web at 10:36:05 UTC, and accessed SharePoint Online at 10:41:48 UTC.

ryan.boyd@cloudora.io — submitted credentials at 09:05:44 UTC. The attacker successfully signed in at 13:22:05 UTC and accessed Outlook Web at 13:25:33 UTC.

Both sign-ins used Windows 11 and Chrome, which were inconsistent with the users' normal United Kingdom activity and device baselines.

Accounts targeted but not breached

Clicked the phishing link but did not submit credentials:

seth.lane@cloudora.io

chloe.price@cloudora.io

hugo.marsh@cloudora.io

dina.said@cloudora.io

No successful sign-ins from the attacker IP were identified for these accounts. They were not confirmed compromised but require direct contact and precautionary password resets.

Received the phishing email but did not click:

adam.clark@cloudora.io

alba.vega@cloudora.io

amelia.frost@cloudora.io

aria.reid@cloudora.io

arjun.mehta@cloudora.io

cole.burke@cloudora.io

daniel.reeve@cloudora.io

dean.page@cloudora.io

ethan.wells@cloudora.io

felix.hart@cloudora.io

finn.gale@cloudora.io

gwen.muir@cloudora.io

isla.grant@cloudora.io

james.holt@cloudora.io

joel.kerr@cloudora.io

jude.ross@cloudora.io

kian.patel@cloudora.io

leah.stone@cloudora.io

lena.voss@cloudora.io

liam.doyle@cloudora.io

lucas.ford@cloudora.io

mira.shah@cloudora.io

noah.bishop@cloudora.io

olivia.kaur@cloudora.io

omar.farah@cloudora.io

priya.nair@cloudora.io

rhys.owen@cloudora.io

sofia.marino@cloudora.io

tara.kemp@cloudora.io

zara.aziz@cloudora.io

These 30 accounts received at least one delivered phishing message but generated no click event

Targeted but protected by quarantine:

emma.hayes@cloudora.io

maya.chen@cloudora.io

nina.cole@cloudora.io

ruth.dean@cloudora.io

Every phishing message sent to these four accounts was quarantined by Exchange Online Protection, so the users did not receive the message in their inboxes.

Accounts investigated and cleared (false positives)

None. No user account was investigated and cleared as a false-positive compromise in this incident.

A separate email false positive was investigated: the "Cloudora Monthly" Mailchimp newsletter was confirmed legitimate because SPF, DKIM and DMARC passed for the genuine cloudora.io domain, and its links pointed to Cloudora's authorised Mailchimp infrastructure.

Emails investigated and cleared

The "Cloudora Monthly" Mailchimp newsletter reported by Adam Clark was investigated and classified as legitimate marketing email. Its authentication aligned with the genuine cloudora.io domain, and it was unrelated to the phishing campaign.

Overall incident scope

- 40 accounts targeted
- 36 accounts received at least one phishing message

- 6 users clicked
- 2 users submitted credentials and were compromised
- 4 users clicked but did not submit credentials
- 30 users received the phish but did not click
- 4 users had every phishing message quarantined
- 1 reported email cleared as a legitimate false positive
- 4 attacker IP addresses identified
- lookalike phishing domain identified

6. Actions taken

What was actually done, by whom, at what time (UTC), in order. Containment first (stop the bleeding), then eradication (remove attacker access and persistence), then verification (prove it worked). An action without a timestamp did not happen.

Time (UTC)	Action	Performed by	Verified how
Not executed — training scenario	Revoke all active sessions and refresh tokens for <code>freya.lynn@cloudora.io</code> and <code>ryan.boyd@cloudora.io</code>	Proposed for Cloudora identity administrator	Confirm both users are forced to authenticate again and that no existing attacker sessions remain active.
Not executed — training scenario	Reset the passwords for both confirmed compromised accounts	Proposed for Cloudora identity administrator	Confirm the previous credentials no longer work and review all subsequent sign-in activity.
Not executed — training scenario	Require and re-register multi-factor authentication for both compromised accounts	Proposed for Cloudora identity administrator	Review the registered authentication methods and confirm that only authorised methods remain.
Not executed — training scenario	Block <code>198.18.44.10</code> , <code>198.18.44.23</code> , <code>198.18.51.7</code> , <code>198.18.7.200</code> , and <code>cloudora-hr-portal.example</code> including all subdomains	Proposed for Cloudora security and email administrators	Confirm the indicators are blocked at the mail gateway, web proxy and relevant identity controls; re-run queries to check for further activity.
Not executed — training scenario	Purge all delivered phishing messages from Cloudora mailboxes using soft deletion or zero-hour auto purge	Proposed for Cloudora messaging administrator	Search all mailboxes for the phishing subjects, senders and URLs and confirm no delivered copies remain.
Not executed — training scenario	Force precautionary password resets and contact the four users who clicked but did not submit credentials	Proposed for Cloudora identity administrator and service desk	Confirm the four resets are complete, speak directly with each user and review their authentication records for suspicious access.
Not executed — training scenario	Send awareness communication to the 30 users who received the phish but did not click	Proposed for Cloudora IT Security	Confirm the communication was delivered and provide a clear reporting route for anyone who later recalls interacting with the email.

Not executed — training scenario	Review Freya Lynn's SharePoint activity and both compromised users' mailbox activity	Proposed for Cloudora SOC, messaging administrator and SharePoint administrator	Identify any files or messages viewed, downloaded, modified, shared, deleted or sent during the attacker sessions.
----------------------------------	--	---	--

7. Recommendations

1. Immediately contain both compromised accounts

Revoke all sessions and refresh tokens for Freya Lynn and Ryan Boyd, reset their credentials and require multi-factor authentication re-registration. This addresses Finding 3, in which the attacker successfully used harvested passwords to access both accounts.

2. Reset and contact the four users who clicked without submitting credentials

Seth Lane, Chloe Price, Hugo Marsh and Dina Said should receive precautionary password resets and direct check-ins. Although no credential submission or attacker sign-in was recorded, they reached the harvesting page and therefore present higher risk than users who did not click.

3. Enforce multi-factor authentication for all Cloudora accounts

Both compromises succeeded using passwords alone. Requiring multi-factor authentication would reduce the likelihood that a harvested password by itself results in account access.

4. Disable legacy authentication where possible

Authentication methods that do not support modern security controls should be disabled so that attackers cannot bypass multi-factor authentication or Conditional Access protections.

5. Move the `cloudora.io` DMARC policy to `p=reject`

Variant A spoofed `payroll@cloudora.io` and failed SPF, DKIM and DMARC. A reject policy would help prevent unauthorised external systems from successfully delivering messages that impersonate the genuine Cloudora domain.

6. Improve detection of lookalike domains

The mail gateway should detect newly observed or lookalike domains resembling `cloudora.io`, including domains containing terms such as `cloudora`, `payroll`, `hr` or `portal`. Variant B passed authentication because it was correctly authenticated for the attacker's own lookalike domain.

7. Alert when external mail claims to originate from `cloudora.io` but fails DMARC

Messages arriving from outside Cloudora while using a `cloudora.io` From address and failing domain authentication should generate a high-priority alert or be rejected.

8. Deploy the phishing-click followed by foreign sign-in detection

The KQL rule developed in Task 4 should alert when a user clicks a phishing link and then successfully authenticates from a different IP and an unexpected country within six hours. The tested rule identified Freya Lynn and Ryan Boyd and remained silent on the four users who clicked without being compromised.

9. Create a high-severity alert for known phishing infrastructure followed by successful access

Any successful authentication from an IP or domain already associated with a confirmed phishing campaign should generate a high-severity incident and automatically map the affected user and IP entities.

10. Permanently block and monitor the identified infrastructure

Block the three sending relays, the attacker sign-in IP and the lookalike domain. Continue monitoring for adjacent domain names, subdomains and nearby infrastructure that may indicate the same actor has rebuilt the campaign.

11. Preserve and promote the employee-reporting process

James Holt's report opened the investigation before automated controls detected the compromise. Cloudora should keep the phishing-reporting button visible, acknowledge employees who report suspicious messages and reinforce that users will not be blamed for reporting mistakes.

12. Conduct deeper post-compromise reviews

Freya's SharePoint activity and both users' mailbox activity should be reviewed for file access, downloads, external sharing, suspicious messages, forwarding rules and other evidence of data exposure. The available logs confirm access but do not prove whether information was stolen.

These recommendations should be prioritised as immediate containment, short-term detection improvements and longer-term identity and email-security controls.

8. Lessons learned

The investigation demonstrated that employee reporting remains an important security control. James Holt's forwarded email opened the incident before an automated detection alerted the SOC. Cloudora should therefore make phishing reporting easy, visible and free from blame.

Message-trace analysis allowed one reported email to be expanded into the full campaign scope. It identified the sending infrastructure, delivery outcomes, click activity and credential submissions. Pivoting from the first confirmed attacker sign-in IP then revealed Ryan Boyd as a second compromised user. The investigation should never stop after identifying the first victim.

The investigation also demonstrated that passing SPF, DKIM and DMARC does not automatically make an email legitimate. Variant B passed all three checks, but only for the attacker-controlled cloudora-hr-portal.example domain. The Mailchimp newsletter also passed authentication, but its DKIM and DMARC alignment matched the genuine cloudora.io domain. Analysts must always ask which domain passed authentication, rather than treating a green result as a safe verdict.

Separating users into confirmed compromises, credential submitters, clickers, near misses and quarantined recipients made the response proportionate. Users who clicked but did not submit credentials required more urgent action than users who only received the email, while users protected by quarantine required no individual containment.

The largest gap was detection speed. Both compromises were visible in the sign-in logs shortly after the phishing clicks. A rule correlating a recent phishing click with a successful foreign sign-in would have raised an alert the same morning rather than relying solely on an employee report.

Finally, the available telemetry had limitations. Outlook Web and SharePoint access were observed, but the logs did not establish whether files or messages were downloaded, modified or stolen. Absence of evidence should not be recorded as proof that no data exposure occurred. Additional mailbox, SharePoint, endpoint and identity telemetry would be required to determine the full impact.